

# NIS2 Compliance Assessment Report

## Organization: Regional Hospital (Medium)

Date: 2026-06-09

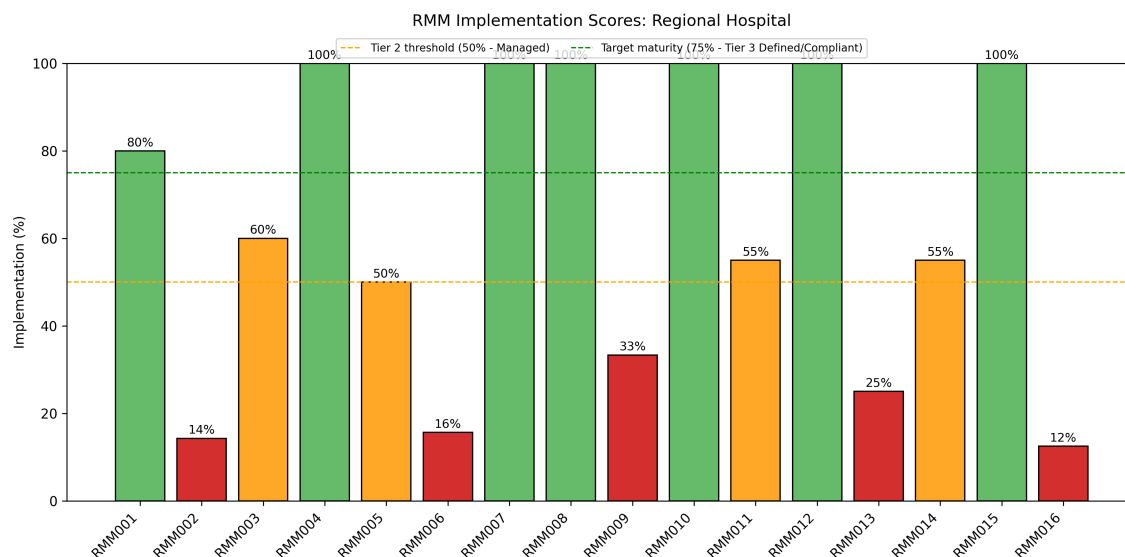
Data source: On-site NIS2 assessment - evidence-referenced responses (auditor-collected, May-Jun 2026)

|                 |                                  |
|-----------------|----------------------------------|
| Overall Score   | 56.2%                            |
| Maturity Tier   | Tier 2 - Managed (Foundational)  |
| Target Maturity | 75% (Tier 3 - Defined/Compliant) |

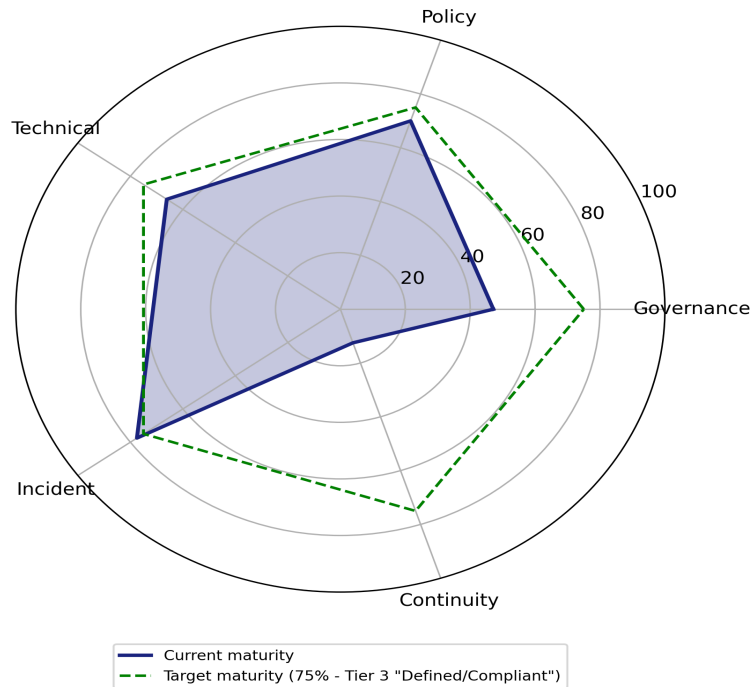
**How to read this score.** Each question is answered Yes (4 pts), Partial (1 pt) or No (0 pts) and multiplied by a weight (critical controls such as MFA and 24h reporting carry higher weight, so RMM scores are *not* weighted equally). Each answer is further scaled by an evidence-assurance factor (None 0.0 / Low 0.5 / Medium 0.8 / High 1.0), so claims without evidence score lower. The overall percentage is the weighted, assurance-adjusted total divided by the maximum achievable. Maturity tiers: Tier 1 Initial 0-49%, Tier 2 Managed 50-74%, Tier 3 Defined/Compliant 75-89%, Tier 4 Optimized 90-100%. The target for a medium healthcare entity is Tier 3 (75%). For this assessment the assurance-adjusted weighted score is 83.2 of a possible 148.0 points = 56.2%, placing the organization in Tier 2.

## Executive Risk Statement

As of 2026-06-09, Regional Hospital scores 56.2% (Tier 2 - Managed (Foundational)) against NIS2 risk-management requirements. The organization has foundational controls in place but is not yet compliant with NIS2; several material gaps remain. The weakest areas are Continuity, Board Governance, Cyber Hygiene. Unremediated gaps directly threaten patient safety (loss of access to EHR, imaging and medication systems), the continuity of clinical services (ransomware or outage with no tested recovery), and expose the organization to legal and regulatory liability under NIS2. This includes management accountability and potential penalties. Leadership should treat the items below as a time-bound program: address the 30-day actions immediately, fund the 60- and 90-day actions in this budget cycle, and review progress against the target maturity at the next board meeting.



Maturity Profile: Regional Hospital



The solid blue area is the current maturity by domain; the green dashed line is the target profile (75%, Tier 3 'Defined/Compliant'). A regional hospital delivers essential healthcare services and is treated as an 'essential entity' under NIS2 (Annex I), so it is expected to reach the Defined/Compliant tier with controls fully documented, implemented and routinely tested, rather than merely Managed. Tier 4 (Optimized) is not required for compliance. Gaps between the blue area and the green line are the work still required in each domain.

## Priority Remediation Plan

Each gap below the target maturity has a control-specific action with an accountable owner, due window, dependencies and the evidence required to close it.

| RMM                               | Now | Target | Priority | Control-specific remediation                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|-----------------------------------|-----|--------|----------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>RMM016</b><br>Continuity       | 12% | 90%    | Critical | Define a BCP with documented RTO/RPO for each critical system like EHR, PACS, LIS, medication systems, and network services. Test disaster recovery annually.<br><b>Owner:</b> IT Operations / Business Continuity Manager <b>Due:</b> 90 days<br><b>Depends on:</b> Critical-asset register (RMM004), DR environment<br><b>Evidence:</b> BCP with per-system RTO/RPO table and annual DR test report                                                                                                                            |
| <b>RMM002</b><br>Board Governance | 14% | 90%    | Critical | Formalize board oversight: minute quarterly cyber reviews, approve an 18-month security budget, and complete mandatory board cyber training.<br><b>Owner:</b> Board / Executive Sponsor <b>Due:</b> 60 days<br><b>Depends on:</b> Board meeting calendar; annual budget cycle<br><b>Evidence:</b> Board minutes, approved budget line, training completion records                                                                                                                                                               |
| <b>RMM006</b><br>Cyber Hygiene    | 16% | 90%    | Critical | Adopt risk-based patch SLAs: critical internet-facing vulnerabilities treated within 48-72h, high within 14 days, others within 30 days, with exceptions documented and formally approved. Test backup restorability annually and make cyber-hygiene training mandatory.<br><b>Owner:</b> IT Operations Lead <b>Due:</b> 30 days<br><b>Depends on:</b> Vulnerability scanning, patch automation, backup platform<br><b>Evidence:</b> Risk-based patch SLA policy, exception register, backup restore-test logs, training records |

| RMM                              | Now | Target | Priority | Control-specific remediation                                                                                                                                                                                                                                                                            |
|----------------------------------|-----|--------|----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>RMM013</b><br>Secure Dev      | 25% | 85%    | Critical | Build security requirements into system acquisition and run vulnerability management across new systems.<br><b>Owner:</b> IT Architecture / CISO <b>Due:</b> 90 days<br><b>Depends on:</b> Procurement process (RMM012)<br><b>Evidence:</b> Secure acquisition checklist and vulnerability scan reports |
| <b>RMM009</b><br>Access Control  | 33% | 100%   | Critical | Enforce MFA on ALL remote and administrative access and apply least-privilege RBAC across systems.<br><b>Owner:</b> IT Security / IAM Lead <b>Due:</b> 30 days<br><b>Depends on:</b> Identity provider (e.g., Okta) rollout<br><b>Evidence:</b> MFA coverage report and privileged-access review        |
| <b>RMM005</b><br>Measurement     | 50% | 85%    | High     | Establish annual control testing/internal audit and a documented process to update measures after every incident.<br><b>Owner:</b> Internal Audit / CISO <b>Due:</b> 90 days<br><b>Depends on:</b> ISMS policy (RMM003)<br><b>Evidence:</b> Audit reports and post-incident review records              |
| <b>RMM011</b><br>Cryptography    | 55% | 90%    | High     | Encrypt patient data at rest and enforce TLS in transit; manage keys through a central key-management service.<br><b>Owner:</b> CISO / IT Security <b>Due:</b> 60 days<br><b>Depends on:</b> Key management service<br><b>Evidence:</b> Encryption configuration evidence and TLS scan results          |
| <b>RMM014</b><br>Incident Resp   | 55% | 90%    | High     | Finalize and approve the Incident Response Plan and run a tabletop exercise within 12 months.<br><b>Owner:</b> CISO / SOC Lead <b>Due:</b> 60 days<br><b>Depends on:</b> Detection capability (RMM015)<br><b>Evidence:</b> Approved IRP and tabletop exercise report                                    |
| <b>RMM003</b><br>Security Policy | 60% | 90%    | Medium   | Approve and publish an ISMS security policy set covering all NIS2 Art.21(2) risk areas; assign policy owners and annual review dates.<br><b>Owner:</b> CISO <b>Due:</b> 60 days<br><b>Depends on:</b> Risk assessment (RMM004)<br><b>Evidence:</b> Signed, version-controlled ISMS policy set           |

## 30-60-90 Day Remediation Roadmap

Sequenced view of the same actions so management can track progress towards target maturity after this assessment.

| Window                   | RMM                     | Now | Target |
|--------------------------|-------------------------|-----|--------|
| Days 0-30 (Immediate)    | RMM006 Cyber Hygiene    | 16% | 90%    |
|                          | RMM009 Access Control   | 33% | 100%   |
| Days 31-60 (Short term)  | RMM002 Board Governance | 14% | 90%    |
|                          | RMM011 Cryptography     | 55% | 90%    |
|                          | RMM014 Incident Resp    | 55% | 90%    |
|                          | RMM003 Security Policy  | 60% | 90%    |
| Days 61-90 (Medium term) | RMM016 Continuity       | 12% | 90%    |
|                          | RMM013 Secure Dev       | 25% | 85%    |
|                          | RMM005 Measurement      | 50% | 85%    |

## Business Continuity: Critical System Recovery Objectives

Recovery Time Objective (RTO) and Recovery Point Objective (RPO) targets for the hospital's critical systems (basis for RMM016). These objectives are validated by the disaster-recovery test schedule below.

| Critical system                           | Criticality       | RTO     | RPO        | Key dependency         |
|-------------------------------------------|-------------------|---------|------------|------------------------|
| Electronic Health Record (EHR)            | Tier 1 - Critical | 4 hours | 15 minutes | Core network, identity |
| Medication management (ePMA / eMAR)       | Tier 1 - Critical | 2 hours | 15 minutes | EHR, core network      |
| Laboratory Information System (LIS)       | Tier 1 - Critical | 4 hours | 30 minutes | EHR, core network      |
| Picture Archiving & Communication (PACS)  | Tier 2 - High     | 8 hours | 1 hour     | Storage, core network  |
| Core network & identity (AD / DNS / DHCP) | Tier 1 - Critical | 1 hour  | 15 minutes | Power, data center     |

### ***Disaster-recovery test schedule***

| Frequency     | Test                                                         | Owner                      |
|---------------|--------------------------------------------------------------|----------------------------|
| Quarterly     | Backup restore test of one Tier 1 system (rotating schedule) | Infrastructure Lead        |
| Semi-annually | Incident & DR tabletop exercise (clinical + IT participants) | CISO / SOC Lead            |
| Annually      | Full DR failover test with main-network isolation            | IT Operations / BC Manager |

## **Incident Reporting & 24-Hour Early-Warning Readiness (Art. 23)**

Operational proof that the organization can submit a NIS2 'early warning' within 24 hours of becoming aware of a significant incident.

| Element            | Detail                                                                                  |
|--------------------|-----------------------------------------------------------------------------------------|
| Reporting owner    | SOC Lead (primary); Duty IT Manager (deputy)                                            |
| Escalation route   | SOC analyst -> SOC Lead -> CISO -> Executive on-call -> national CSIRT / NCSC           |
| Out-of-hours cover | 24/7 on-call rota (ref OPS-ROTA-2026), 15-minute acknowledgement SLA                    |
| Reporting template | NCSC early-warning template TMPL-EW-01 (held in IRP-PROC-007 v1.0)                      |
| Statutory timeline | Early warning within 24h, incident notification within 72h, final report within 1 month |
| Test evidence      | Simulated early-warning submission TEST-EW-2026-01, completed 2026-03-08                |

## **Consistency Checks**

- MFA is not enforced for admin/remote access (Q17). This is a critical control; consider immediate remediation.

## Appendix: Detailed Findings

| ID | RMM    | Article      | Question                                             | Resp.   | Assur. | Evidence (document reference)                                                                                                                                                    | Pts |
|----|--------|--------------|------------------------------------------------------|---------|--------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----|
| 1  | RMM001 | Art.20(1)    | Is there a designated officer for NIS2 compliance?   | Yes     | Medium | Appointment letter 'NIS2 Compliance Officer' (S. Haran), ref HR-APP-2025-114, dated 2025-11-03; owner: HR Director; stored in DMS/Governance/NIS2 (role not yet board-ratified). | 4.0 |
| 2  | RMM002 | Art.20(1)    | Does the board explicitly approve cyber measures?    | Partial | High   | Board Minutes ref BM-2026-Q1, 2026-02-18, agenda item 7 'Cyber Security Measures - Approval'; owner: Company Secretary; BoardPortal.                                             | 1.5 |
| 3  | RMM002 | Art.20(1)    | Is there an approved cyber budget for 18 months?     | No      | Low    | Draft Capital Budget FY2026 (FIN-BUD-2026 v0.4); cyber line funded for 6 of 18 months only; owner: CFO; Finance DMS.                                                             | 0.0 |
| 4  | RMM002 | Art.20(2)    | Do board members undergo mandatory cyber training?   | Partial | Low    | LMS completion report LMS-RPT-2026-02 (2026-02-28): board cyber module 45% complete; owner: L&D; Manager.                                                                        | 1.0 |
| 5  | RMM003 | Art.21(2)(a) | Is there a documented Security Policy (ISMS)?        | Yes     | High   | Information Security Policy ISMS-POL-001 v2.3, approved 2026-01-20; owner: CISO; stored in DMS/ISMS.                                                                             | 6.0 |
| 6  | RMM003 | Art.21(2)    | Does policy cover all NIS2 risk areas?               | No      | Medium | ISMS gap analysis GAP-2026-03 (2026-03-12): supply-chain and cryptography sections incomplete; owner: CISO.                                                                      | 0.0 |
| 7  | RMM004 | Art.21(2)(a) | Are risk assessments conducted annually?             | Yes     | High   | Enterprise Risk Assessment RA-2026-001, 2026-02-05 (ISO 27005 method); owner: Risk Manager; GRC platform.                                                                        | 6.0 |
| 8  | RMM004 | Art.21(2)(a) | Are critical assets (e.g., EHR) formally identified? | Yes     | High   | Critical Asset Register CAR-2026 v1.2, 2026-02-10 (EHR, PACS, LIS classified Tier 1); owner: IT Asset Manager.                                                                   | 4.0 |
| 9  | RMM005 | Art.21(2)(f) | Are measures audited/tested annually?                | No      | High   | No independent control audit on record; last internal review IR-2024-09 (>12 months old); owner: Internal Audit.                                                                 | 0.0 |
| 10 | RMM005 | Art.21(2)(a) | Is there a process to update measures post-incident? | Yes     | High   | Post-Incident Review procedure PROC-IR-004 v1.1; worked example PIR-2025-21 closure actions; owner: SOC Lead.                                                                    | 4.0 |
| 11 | RMM006 | Art.21(2)(e) | Is patching performed within defined SLAs?           | Partial | High   | Patch Management Standard ITS-STD-007 v1.0 (availability SLA 99.5%, no risk-based vulnerability SLA); Intune/WSUS compliance reports Q1-2026; owner: IT Operations.              | 1.5 |
| 12 | RMM006 | Art.21(2)(c) | Are backups tested for restorability annually?       | No      | High   | Backup Policy BKP-POL-002; Veeam job logs confirm backups run, but no restore test recorded in 12 months; owner: Infrastructure Lead.                                            | 0.0 |
| 13 | RMM006 | Art.21(2)(g) | Is cyber hygiene training mandatory for all staff?   | Partial | High   | Security Awareness report LMS-RPT-2026-03: 68% staff completion; mandatory enrolment pending; owner: L&D; Manager.                                                               | 1.0 |

| ID | RMM    | Article      | Question                                             | Resp.   | Assur. | Evidence (document reference)                                                                                                                     | Pts |
|----|--------|--------------|------------------------------------------------------|---------|--------|---------------------------------------------------------------------------------------------------------------------------------------------------|-----|
| 14 | RMM007 | Art.21(2)(i) | Is the asset inventory up-to-date?                   | Yes     | High   | CMDB export CMDB-2026-05-01 (Lansweeper), reconciled monthly; owner: IT Asset Manager; ServiceNow.                                                | 4.0 |
| 15 | RMM008 | Art.21(2)(i) | Are background checks performed for sensitive roles? | Yes     | High   | Pre-employment screening register HR-VET-2026 (Garda vetting for clinical/privileged roles); owner: HR Director.                                  | 4.0 |
| 16 | RMM008 | Art.21(2)(i) | Are access rights revoked immediately upon exit?     | Yes     | High   | Joiner-Mover-Leaver SOP HR-IT-SOP-003 v2.0; leaver deprovisioning tickets sample SNOW-LVR-2026-Q1; owner: IAM Team.                               | 4.0 |
| 17 | RMM009 | Art.21(2)(j) | Is MFA enforced for ALL remote/admin access?         | No      | High   | IAM coverage report IAM-RPT-2026-04: MFA on VPN only (62% of accounts); admin consoles pending Okta rollout (project OKTA-2026); owner: IAM Lead. | 0.0 |
| 18 | RMM009 | Art.21(2)(j) | Is 'Least Privilege' strictly enforced?              | Yes     | High   | Privileged Access Review PAR-2026-Q1 (2026-03-30), AD/LDAP group recertification; owner: IT Security.                                             | 4.0 |
| 19 | RMM010 | Art.21(2)    | Are physical server rooms secured?                   | Yes     | High   | Data centre access log DC-ACC-2026 (badge + biometric); environmental monitoring report FAC-ENV-2026-Q1; owner: Facilities.                       | 4.0 |
| 20 | RMM011 | Art.21(2)(h) | Is patient data encrypted at rest?                   | Partial | High   | Encryption Standard CRY-STD-005; EHR database TDE enabled; some legacy file shares unencrypted per GAP-2026-03; owner: CISO.                      | 1.5 |
| 21 | RMM011 | Art.21(2)(h) | Is data encrypted in transit (TLS)?                  | Yes     | High   | TLS configuration scan SSLSCAN-2026-04 (grade A, TLS 1.2/1.3); SFTP for external transfers; owner: Network Team.                                  | 4.0 |
| 22 | RMM012 | Art.21(2)(d) | Do supplier contracts include security SLAs?         | Yes     | High   | Vendor Contract Register VEN-CON-2026; security schedule and right-to-audit clause in top-10 contracts; owner: Procurement.                       | 6.0 |
| 23 | RMM012 | Art.21(2)(d) | Are critical vendors risk-assessed?                  | Yes     | High   | Third-party risk assessments TPRM-2026 (incl. GG Medicines audit report GGM-AUD-2026-02); owner: Vendor Risk.                                     | 4.0 |
| 24 | RMM013 | Art.21(2)(e) | Is security built into system acquisition?           | Partial | High   | Secure-by-design checklist SDLC-CHK-009 applied to 2 of 5 recent acquisitions; owner: IT Architecture.                                            | 1.0 |
| 25 | RMM014 | Art.21(2)(b) | Is there a documented Incident Response Plan?        | Partial | High   | Incident Response Plan IRP-PLAN-006 v0.9 (draft, pending CISO approval); owner: CISO; DMS/ISMS.                                                   | 1.5 |
| 26 | RMM014 | Art.21(2)(b) | Has the IRP been tested (tabletop) in 12 months?     | Yes     | High   | Tabletop exercise report TTX-2025-11 (ransomware scenario), conducted 2025-11-22; owner: SOC Lead.                                                | 4.0 |

| ID | RMM    | Article      | Question                                       | Resp.   | Assur. | Evidence (document reference)                                                                                                                                                                               | Pts |
|----|--------|--------------|------------------------------------------------|---------|--------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----|
| 27 | RMM015 | Art.23(3)    | Can you submit an 'Early Warning' within 24h?  | Yes     | High   | Incident Reporting Procedure IRP-PROC-007 v1.0 with NCSC early-warning template TMPL-EW-01; named owner SOC Lead, 24/7 on-call rota OPS-ROTA-2026; test submission TEST-EW-2026-01 (2026-03-08, simulated). | 8.0 |
| 28 | RMM015 | Art.21(2)(b) | Are detection mechanisms (IDS/SIEM) in place?  | Yes     | High   | SIEM onboarding report SIEM-2026-01 (Microsoft Sentinel), 24/7 monitoring; owner: SOC.                                                                                                                      | 4.0 |
| 29 | RMM016 | Art.21(2)(c) | Is there a Business Continuity Plan with RTOs? | Partial | High   | Business Continuity Plan BCP-PLAN-010 v0.7 (draft): RTO/RPO defined for EHR and network only; PACS, LIS and medication systems pending; owner: BC Manager.                                                  | 1.5 |
| 30 | RMM016 | Art.21(2)(c) | Are DR procedures tested annually?             | No      | High   | No full DR failover test on record; last partial test DR-TEST-2024-05 (>12 months old); owner: Infrastructure Lead.                                                                                         | 0.0 |